

CONHECIMENTOS ESPECÍFICOS

Gestão de Identidade e Acesso



Presidente: Gabriel Granjeiro

Vice-Presidente: Rodrigo Calado

Diretor Pedagógico: Erico Teixeira

Diretora de Produção Educacional: Vivian Higashi

Gerente de Produção Digital: Bárbara Guerra

Coordenadora Pedagógica: Élica Lopes

Todo o material desta apostila (incluindo textos e imagens) está protegido por direitos autorais do Gran. Será proibida toda forma de plágio, cópia, reprodução ou qualquer outra forma de uso, não autorizada expressamente, seja ela onerosa ou não, sujeitando-se o transgressor às penalidades previstas civil e criminalmente.

CÓDIGO:

250205551812



PATRÍCIA QUINTÃO

Mestre em Engenharia de Sistemas e computação pela COPPE/UFRJ, Especialista em Gerência de Informática e Bacharel em Informática pela UFV. Atualmente é professora no Gran Cursos Online; Analista Legislativo (Área de Governança de TI), na Assembleia Legislativa de MG; Escritora e Personal & Professional Coach. Atua como professora de Cursinhos e Faculdades, na área de Tecnologia da Informação, desde 2008. É membro: da Sociedade Brasileira de Coaching, do PMI, da ISACA, da Comissão de Estudo de Técnicas de Segurança (CE-21:027.00) da ABNT, responsável pela elaboração das normas brasileiras sobre gestão da Segurança da Informação. Autora dos livros: Informática FCC – Questões comentadas e organizadas por assunto, 3ª. edição e 1001 questões comentadas de informática (Cespe/UnB), 2ª. edição, pela Editora Gen/Método. Foi aprovada nos seguintes concursos: Analista Legislativo, na especialidade de Administração de Rede, na Assembleia Legislativa do Estado de MG; Professora titular do Departamento de Ciência da Computação do Instituto Federal de Educação, Ciência e Tecnologia; Professora substituta do DCC da UFJF; Analista de TI/Suporte, PRODABEL; Analista do Ministério Público MG; Analista de Sistemas, DATAPREV, Segurança da Informação; Analista de Sistemas, INFRAERO; Analista – TIC, PRODEMGE; Analista de Sistemas, Prefeitura de Juiz de Fora; Analista de Sistemas, SERPRO; Analista Judiciário (Informática), TRF 2ª Região RJ/ES, etc.

GRAN
CONCURSOS

SUMÁRIO

Apresentação	5
Gestão de Identidade e Acesso.....	6
1. Introdução ao Gerenciamento de Acesso e Identidade.....	7
1.1. Definição e Importância.....	7
1.2. Componentes Principais	8
1.3. Conceitos de Identidade, Autenticação e Autorização	8
2. Modelos de Controle de Acesso	10
2.1. Controle de Acesso Discrecional (DAC)	10
2.2. Controle de Acesso Obrigatório (MAC).....	11
2.3. Controle de Acesso Baseado em Função (RBAC).....	11
2.4. Controle de Acesso Baseado em Atributos (ABAC).....	12
3. Tecnologias de Autenticação.....	13
3.1. Senhas e PINs	13
3.2. Autenticação de Dois Fatores (2FA)	14
3.3. Autenticação Biométrica	16
3.4. Certificados Digitais e PKI	16
4. Protocolos de Autenticação e Autorização	17
4.1. LDAP	17
4.2. SAML.....	18
4.3. OAuth 2.0.....	18
4.4. OpenID Connect	18
5. Single Sign-On (SSO)	18
5.1. Conceito e Funcionamento	18
5.2. Vantagens e Desvantagens	19
5.3. Federação.....	19
5.4. Implementação Prática	19

6. Gestão de Identidades	20
6.1. Ciclo de Vida da Identidade	20
6.2. Provisionamento e Desprovisionamento	21
6.3. Sincronização de Identidades	21
7. Governança de Acesso	21
7.1. Políticas de Acesso	21
7.2. Auditoria e Conformidade	21
7.3. Ferramentas de Gerenciamento de Acesso e Identidade	21
8. Tendências e Inovações	21
8.1. Identidade como Serviço (IDaaS)	21
8.2. Blockchain para Identidade	21
8.3. Futuro do Gerenciamento de Identidade	23
Resumo	24
Questões Comentadas em Aula	26
Questões de Concurso.	28
Gabarito	33
Gabarito Comentado.	34
Referências	46

APRESENTAÇÃO

Olá, querido (a) amigo(a), tudo bem?

Seja bem-vindo (a) à aula de **Gerenciamento de Acesso e Identidade (IAM, do inglês Identity and Access Management)**. Em um mundo cada vez mais digital e interconectado, a segurança da informação tornou-se uma prioridade inegável para organizações de todos os portes e setores.

Neste contexto, o IAM emerge como um pilar fundamental na proteção de dados e recursos, garantindo que apenas as pessoas certas tenham acesso às informações corretas, no momento apropriado.

Prepare-se para uma jornada desafiadora e recompensadora, e força nos estudos!

Um abraço,

Prof^a Patrícia Lima Quintão

@patricialquintao

GESTÃO DE IDENTIDADE E ACESSO

Termos, Definições e Abreviaturas

A seguir destacamos uma **lista de Termos e Definições Essenciais** em Gerenciamento de Acesso e Identidade (IAM):

- **Gerenciamento de Acesso e Identidade (IAM – *Identity and Access Management*):** conjunto de processos, políticas e tecnologias que garantem que as pessoas e entidades com identidades digitais tenham o nível certo de acesso aos recursos da empresa.
- **Identidade Digital:** credenciais necessárias para que um usuário obtenha acesso a recursos online ou em uma rede corporativa.
- **Autenticação:** processo de verificação da identidade de um usuário ou entidade.
- **Autorização:** processo que permite determinar quais direitos e permissões um usuário autenticado tem no sistema.
- **Auditoria (*Accounting*):** coleta de informações relacionadas à utilização, pelos usuários, dos recursos de um sistema.
- **Controle de Acesso Discrecionário (DAC – *Discretionary Access Control*):** política de controle de acesso determinada pelo proprietário do recurso.
- **Controle de Acesso Obrigatório (MAC – *Mandatory Access Control*):** política de acesso determinada pelo sistema e não pelo proprietário do recurso.
- **Controle de Acesso Baseado em Função (RBAC – *Role Based Access Control*):** abordagem para restringir o acesso a usuários autorizados com base em suas funções na organização.
- **Controle de Acesso Baseado em Atributos (ABAC – *Attribute-Based Access Control*):** modelo de controle de acesso que avalia um conjunto de atributos para determinar se um usuário pode acessar um recurso.
- **Autenticação Multifator (MFA – *Multi-Factor Authentication*):** processo que exige que os usuários forneçam uma combinação de fatores de autenticação para verificar suas identidades.
- **Logon Único (SSO – *Single Sign-On*):** permite que um usuário autorizado faça logon com segurança em várias aplicações e sites usando apenas um conjunto de credenciais.
- **Federação:** permite o SSO sem senhas, utilizando um protocolo de identidade padrão como SAML ou WS-Federation.
- **Token de Autenticação:** dispositivo físico ou software que gera códigos vinculados a um dispositivo, usuário ou conta, usados como parte de um processo de autenticação.
- **Listas de Controle de Acesso (ACLs – *Access Control Lists*):** listas que definem os direitos e permissões que são dados a um sujeito sobre determinado objeto.

- **Provisionamento:** processo de criação, manutenção e desativação de contas de usuários e seus respectivos direitos de acesso em sistemas e aplicações.
- **Desprovisionamento:** processo de remoção ou revogação do acesso de um usuário a sistemas e aplicações, geralmente quando um funcionário deixa a organização ou muda de função.
- **Política de Acesso:** conjunto de regras e diretrizes que definem quem pode acessar quais recursos e sob quais condições.
- **Rótulo de Segurança:** classificação atribuída a um recurso ou usuário que indica seu nível de confidencialidade ou autorização.
- **Atributo:** característica ou propriedade de um usuário, recurso ou ambiente que pode ser usada para tomar decisões de acesso.
- **Identidade como Serviço (IDaaS - Identity as a Service):** modelo de serviço em nuvem que oferece funcionalidades de IAM, como autenticação, autorização e gestão de identidades.

1. INTRODUÇÃO AO GERENCIAMENTO DE ACESSO E IDENTIDADE

1.1. DEFINIÇÃO E IMPORTÂNCIA

O **Gerenciamento de Acesso e Identidade (IAM, do inglês Identity and Access Management)** é definido como um conjunto abrangente de políticas, processos e tecnologias que visam garantir que as pessoas e entidades digitais certas tenham o nível de acesso apropriado aos recursos da organização (ROUSE, 2021). Em termos mais simples, o **IAM é a disciplina que governa quem pode acessar o quê, quando e como, dentro de um ambiente digital.**

A importância do IAM reside na sua capacidade de equilibrar a segurança e a produtividade. Ao implementar um sistema de IAM eficaz, as organizações podem:

- **proteger ativos críticos:** impedir o acesso não autorizado a dados confidenciais, sistemas e aplicações, reduzindo o risco de violações de dados e ataques cibernéticos (SAILPOINT, 2024);
- **garantir conformidade:** cumprir regulamentações e normas de segurança, como LGPD, ISO 27001, evitando multas e sanções legais (OKTA, 2024);
- **aumentar a eficiência operacional:** automatizar processos de provisionamento e desprovisionamento de usuários, reduzindo a carga de trabalho da equipe de TI e melhorando a experiência do usuário (ROUSE, 2021);

- **melhorar a visibilidade e o controle:** obter uma visão clara de quem tem acesso a quais recursos, facilitando a auditoria e a detecção de atividades suspeitas (SAILPOINT, 2024);
- **reduzir custos:** otimizar o uso de recursos e evitar perdas financeiras decorrentes de incidentes de segurança (OKTA, 2024).

1.2. COMPONENTES PRINCIPAIS

Um **sistema de IAM abrangente** é composto por diversos componentes que trabalham em conjunto para garantir a segurança e a eficiência do acesso aos recursos.

Os **principais componentes** estão relacionados a seguir:

Gestão de Identidades	Processos e tecnologias para criar, manter e gerenciar identidades digitais de usuários, dispositivos e aplicações (ROUSE, 2021).
Autenticação	Mecanismos para verificar a identidade de um usuário ou dispositivo , como senhas, autenticação multifator (MFA) e biometria (SAILPOINT, 2024).
Autorização	Políticas e controles que determinam quais recursos um usuário autenticado pode acessar e quais ações ele pode realizar (OKTA, 2024).
Controle de Acesso	Modelos e tecnologias para restringir o acesso a recursos com base em políticas de segurança (ROUSE, 2021).
Auditoria e Monitoramento	Ferramentas para rastrear e registrar atividades de acesso , permitindo a detecção de anomalias e a investigação de incidentes (SAILPOINT, 2024).
Governança de Acesso	Processos para garantir que as políticas de acesso sejam aplicadas de forma consistente e que os riscos de segurança sejam gerenciados de forma eficaz (OKTA, 2024).

1.3. CONCEITOS DE IDENTIDADE, AUTENTICAÇÃO E AUTORIZAÇÃO



Obs.: IDENTIFICAÇÃO: é a capacidade de extrair informações de um usuário ou aplicação as quais o identifiquem unicamente.

AUTENTICAÇÃO: é a capacidade de garantir que um usuário, sistema ou informação é mesmo quem alega ser. A autenticação é essencial para a segurança dos sistemas, ao validar a identificação dos usuários, concedendo-lhes a **AUTORIZAÇÃO** para o acesso aos recursos.

Para entender o funcionamento do IAM, é fundamental compreender os conceitos de **identidade**, **autenticação** e **autorização**:

- **Identidade:** representação digital de um usuário, dispositivo ou aplicação em um sistema. A identidade inclui atributos como nome, cargo, departamento e privilégios de acesso (ROUSE, 2021). A **identificação** é a capacidade de extrair informações de um usuário ou aplicação as quais o identifiquem unicamente.
- **Autenticação:** processo de verificação da identidade de um usuário ou dispositivo. A autenticação garante que a pessoa ou dispositivo que está tentando acessar um recurso é quem afirma ser (SAILPOINT, 2024). Métodos comuns de autenticação incluem senhas, autenticação multifator (MFA) e biometria.
- **Autorização:** processo de determinar quais recursos um usuário autenticado pode acessar e quais ações ele pode realizar (OKTA, 2024). A autorização garante que os usuários tenham apenas o acesso necessário para realizar suas tarefas, minimizando o risco de acesso não autorizado a dados confidenciais.

Em resumo, o IAM é uma **disciplina essencial para proteger os ativos digitais das organizações**, garantindo que apenas as pessoas certas tenham acesso aos recursos certos, no momento certo (OKTA, 2024). Ao implementar um sistema de IAM eficaz, as organizações podem fortalecer sua postura de segurança, cumprir regulamentações e aumentar a eficiência operacional (ROUSE, 2021).

DIRETO DO CONCURSO



001. (CESPE / CEBRASPE/BANESE - TÉCNICO BANCÁRIO III - ÁREA DE INFORMÁTICA – DESENVOLVIMENTO/2021) No que se refere a qualidade de software e segurança no desenvolvimento, julgue o item que se segue.

Um dos mecanismos de proteção para aplicações e servidores web é a autenticação, que permite o acesso apenas a usuários com as devidas credenciais.



A **autenticação** é um mecanismo fundamental de proteção para aplicações e servidores web. Ela assegura que apenas usuários com credenciais válidas possam acessar o sistema, ajudando a proteger informações e recursos contra acessos não autorizados.

Certo.

002. (CESPE/SEFAZ-AL - AUDITOR DE FINANÇAS E CONTROLE DE ARRECADAÇÃO DA FAZENDA ESTADUAL/2020) Julgue o próximo item, relativo a segurança da informação.

Identificação e autenticação são requisitos de segurança da informação que consistem em identificar usuários do sistema e verificar as suas identidades, como pré-requisito para permitir o acesso desses usuários ao sistema.



Identificação e autenticação são requisitos essenciais de segurança da informação. A **identificação** envolve reconhecer um usuário único no sistema, enquanto a **autenticação** verifica a identidade do usuário para garantir que ele é quem afirma ser, antes de permitir o acesso. Esses passos são fundamentais para controlar o acesso e proteger dados e recursos do sistema.

Certo.

2. MODELOS DE CONTROLE DE ACESSO

Os principais **modelos de controle de acesso** são listados a seguir:

- **Controle de Acesso Discricionário (DAC)**
- **Controle de Acesso Obrigatório (MAC)**
- **Controle de Acesso Baseado em Função (RBAC)**
- **Controle de Acesso Baseado em Atributos (ABAC)**

Vamos às suas principais **características**:

2.1. CONTROLE DE ACESSO DISCRICIONÁRIO (DAC)

O **Controle de Acesso Discricionário (DAC)** é um modelo no qual o **proprietário do recurso (objeto)** decide quem tem permissão para acessá-lo e quais privilégios esse acesso concede. Nesse caso, o proprietário tem total discricção sobre quem pode acessar seus recursos.

Proprietário	Todo objeto no sistema deve ter um proprietário.
Permissões	O proprietário define as permissões de acesso e pode transferir a propriedade.

Exemplo:

Em um sistema de arquivos, um usuário cria um documento. Esse usuário é o proprietário do documento e pode decidir quem pode ler, escrever ou executar o arquivo.

- Vantagens: simplicidade na implementação e gestão; flexibilidade para os proprietários dos recursos.
- Desvantagens: risco de segurança se os proprietários não gerenciarem adequadamente as permissões; dificuldade em manter a consistência das políticas de segurança em toda a organização.

2.2. CONTROLE DE ACESSO OBRIGATÓRIO (MAC)

O **Controle de Acesso Obrigatório (MAC)** é um modelo no qual o sistema, e não o proprietário do recurso, determina quem tem permissão para acessar o recurso. Este modelo é **usado em ambientes nos quais a segurança é crítica**, como em sistemas governamentais e militares.

Rótulos de Segurança	Cada recurso e usuário recebe um rótulo de segurança que indica seu nível de confidencialidade.
Políticas de Acesso	O sistema impõe políticas de acesso baseadas nesses rótulos.

Exemplo:

Em um sistema militar, um documento classificado como “Confidencial” só pode ser acessado por usuários com uma autorização de segurança igual ou superior a “Confidencial”.

- Vantagens: segurança robusta e centralizada; redução do risco de decisões de acesso inconsistentes.
- Desvantagens: complexidade na implementação e gestão; menos flexibilidade para os usuários.

2.3. CONTROLE DE ACESSO BASEADO EM FUNÇÃO (RBAC)

O **Controle de Acesso Baseado em Função (RBAC)** é um modelo que atribui permissões de acesso com base nas funções que os usuários desempenham na organização. Em vez de atribuir permissões diretamente a usuários individuais, **as permissões são atribuídas a funções, e os usuários são associados a essas funções.**

Funções	Conjuntos de permissões associadas a um determinado papel na organização.
Atribuição de Usuários	Usuários são atribuídos a funções, herdando as permissões associadas a essas funções.

Exemplo:

Em um sistema de gestão de recursos humanos, a função “Gerente” pode ter permissão para acessar informações salariais, enquanto a função “Funcionário” não tem essa permissão.

- Vantagens: simplificação da gestão de permissões; facilidade na adaptação às mudanças organizacionais.
- Desvantagens: requer uma definição clara das funções na organização. Pode ser menos flexível do que outros modelos em cenários específicos.

2.4. CONTROLE DE ACESSO BASEADO EM ATRIBUTOS (ABAC)

O **Controle de Acesso Baseado em Atributos (ABAC)** é um modelo que avalia um conjunto de atributos para determinar se um usuário pode acessar um recurso. Esses atributos podem incluir características do usuário, do recurso, e do ambiente.

Atributos do Usuário	Cargo, departamento, localização, etc.
Atributos do Recurso	Tipo de arquivo, nível de confidencialidade, etc.
Atributos do Ambiente	Horário, localização da rede, etc.
Políticas	Regras que combinam esses atributos para tomar decisões de acesso.

Exemplo:

Um usuário só pode acessar um determinado arquivo se ele for do departamento de *marketing*, o arquivo for classificado como “Marketing” e o acesso ocorrer durante o horário de expediente.

- Vantagens: flexibilidade e granularidade na definição das políticas de acesso; capacidade de lidar com cenários complexos.
- Desvantagens: complexidade na implementação e gestão das políticas; requer um bom entendimento dos atributos disponíveis e suas relações.

Veja a **tabela comparativa** que destaca os principais pontos de cada modelo:

CARACTERÍSTICA	DAC	MAC	RBAC	ABAC
Controle Decisão	Proprietário do recurso	Sistema	Funções	Atributos
Foco	Flexibilidade	Segurança	Gestão simplificada	Granularidade e Flexibilidade
Implementação	Simples	Complexa	Moderada	Complexa
Uso Ideal	Ambientes com baixa criticidade	Ambientes com alta criticidade	Organizações com funções bem definidas	Ambientes complexos com requisitos de acesso variados.

Exemplo	Permissões de arquivo em um SO (Sistema Operacional)	Acesso a documentos confidenciais em um sistema militar	Acesso a sistemas de RH baseado em cargos	Acesso a dados com base em localização, cargo e tipo de informação.
Vantagens	Flexibilidade, simplicidade	Segurança, Centralização	Facilidade de gestão, escalabilidade	Flexibilidade, precisão.
Desvantagens	Risco de má gestão, inconsistência	Complexidade, rigidez	Dependência da estrutura organizacional	Complexidade na definição das políticas.

3. TECNOLOGIAS DE AUTENTICAÇÃO

A **autenticação** é um componente crítico do Gerenciamento de Acesso e Identidade (IAM), responsável por **verificar a identidade de um usuário, dispositivo ou aplicação antes de conceder acesso a um sistema ou recurso**.

Diversas **tecnologias de autenticação** estão disponíveis, cada uma com seus próprios pontos fortes e fracos. A escolha da tecnologia de autenticação mais adequada depende das necessidades específicas da organização, do nível de segurança desejado e da experiência do usuário.

3.1. SENHAS E PINS

Senhas e PINs (Números de Identificação Pessoal) são as formas mais tradicionais e amplamente utilizadas de autenticação.

Uma senha é uma sequência secreta de caracteres que um usuário associa à sua identidade, enquanto um PIN é uma sequência numérica.

Funcionamento: durante o processo de autenticação, o usuário fornece sua senha ou PIN, que é comparado com a versão armazenada no sistema. Se as duas versões corresponderem, a identidade do usuário é verificada e o acesso é concedido (SMITH, 2022).

Vantagens:

- simplicidade na implementação e uso;
- baixo custo.

Desvantagens:

- vulnerabilidade a ataques como *phishing*, *brute force* (força bruta) e *keylogging* (NIST, 2023);
- dificuldade em garantir senhas fortes e únicas para todos os usuários;
- alto custo de suporte devido a esquecimentos de senha.

Para mitigar as desvantagens das senhas, é recomendável implementar políticas de senhas fortes, exigir a troca periódica de senhas e educar os usuários sobre os riscos de segurança.

3.2. AUTENTICAÇÃO DE DOIS FATORES (2FA)

A **Autenticação de Dois Fatores (2FA)** é uma **camada adicional de segurança** que exige que os usuários forneçam dois fatores de autenticação diferentes para verificar sua identidade.

Os **fatores de autenticação** são geralmente categorizados em:

Algo que o usuário TEM	São utilizados objetos específicos como cartões de identificação, <i>smart cards</i> , tokens USB .
Algo que o usuário CONHECE /SABE	São utilizadas senhas fixas, <i>one-time passwords</i> , sistemas de desafio-resposta.
Algo que o usuário É	Geralmente são usados <u>meios biométricos</u> , como impressão digital, padrão retinal, padrão de voz, reconhecimento de assinatura, reconhecimento facial.

Funcionamento: após fornecer sua senha (primeiro fator), o usuário é solicitado a fornecer um segundo fator de autenticação, como um código enviado para seu *smartphone* via SMS, um código gerado por um aplicativo autenticador ou uma impressão digital (BROWN, 2024).

Vantagens:

- aumento significativo da segurança em comparação com senhas simples;
- proteção contra ataques como *phishing* e roubo de credenciais.

Desvantagens:

- maior complexidade na implementação e uso;
- possível inconveniente para os usuários.
- Vulnerabilidade a ataques de SIM swapping e engenharia social.

A 2FA é uma medida de segurança eficaz para proteger contas e sistemas contra acesso não autorizado. No entanto, é importante escolher os fatores de autenticação adequados e implementar medidas de segurança adicionais para mitigar os riscos.

DIRETO DO CONCURSO

- 003.** (FADESP/TÉCNICO (PREF IGARAPÉ-MIRI)/INFORMÁTICA/2024) Ao comparar os mecanismos de autenticação de um fator e dois fatores, é correto afirmar que
- a autenticação de dois fatores oferece maior segurança, mas é mais difícil de implementar do que a autenticação de um fator.
 - a autenticação de um fator oferece maior segurança porque requer apenas uma credencial para autenticação, enquanto que a autenticação de dois fatores é mais suscetível a ataques de phishing.

c) a autenticação de um fator oferece proteção adicional contra acessos não autorizados, mas pode ser contornada por usuários mal intencionados, tornando-se menos eficaz que a autenticação de dois fatores.

d) as autenticações de um fator e dois fatores possuem o mesmo nível de segurança, mas a autenticação de dois fatores é mais conveniente para o usuário.



a) Certa. A autenticação de dois fatores (2FA) oferece maior segurança porque combina dois elementos diferentes para verificar a identidade do usuário, como algo que ele sabe (senha) e algo que ele tem (um código enviado para o celular). No entanto, a implementação de 2FA pode ser mais complexa comparada à autenticação de um fator, que geralmente envolve apenas uma senha.

b) Errada. A autenticação de um fator requer apenas uma credencial, como uma senha. Não oferece a mesma segurança que 2FA, pois depende de um único ponto de falha. 2FA é geralmente mais resistente a ataques de *phishing*, pois mesmo que a senha seja capturada, o segundo fator ainda protege o acesso.

c) Errada. É verdade que a autenticação de um fator é mais fácil de contornar, já que depende apenas de uma única senha. Isso a torna menos segura em comparação com 2FA.

d) Errada. As autenticações de um fator e dois fatores não possuem o mesmo nível de segurança. 2FA é consideravelmente mais seguro. 2FA pode ser visto como menos conveniente para o usuário, já que requer passos adicionais para autenticação

Letra a.

004. (CESPE/CEBRASPE)/SERPRO/ANALISTA - ESPECIALIZAÇÃO: DESENVOLVIMENTO DE SISTEMAS/2021) No que se refere a autenticação e riscos de segurança, julgue o item subsequente. Os tokens de autenticação, que podem ser dispositivos físicos ou podem existir em software, geram códigos vinculados a determinado dispositivo, usuário ou conta, que podem ser usados uma vez como parte de um processo de autenticação em um intervalo de tempo.



Tokens de autenticação, tanto físicos quanto em software, geram códigos temporários vinculados a um dispositivo, usuário ou conta. Esses códigos, conhecidos como OTPs (One-Time Passwords), são usados uma única vez dentro de um intervalo de tempo específico, oferecendo uma camada adicional de segurança ao processo de autenticação. Este método ajuda a proteger contra-ataques, como o *phishing* e o acesso não autorizado

Certo.

3.3. AUTENTICAÇÃO BIOMÉTRICA

A **autenticação biométrica** utiliza características biológicas únicas de um indivíduo para verificar sua identidade. As tecnologias biométricas mais comuns incluem: **impressão Digital, reconhecimento Facial, leitura da Íris** (análise dos padrões únicos da íris do olho); **reconhecimento de Voz** (análise das características vocais de um indivíduo).

Funcionamento: durante o processo de autenticação, o usuário fornece sua amostra biométrica, que é comparada com a versão armazenada no sistema. Se as duas versões corresponderem, a identidade do usuário é verificada e o acesso é concedido (Garcia, 2023).

Vantagens:

- alta segurança devido à unicidade das características biométricas;
- conveniência para os usuários;
- dificuldade em falsificar ou roubar dados biométricos.

Desvantagens:

- custo elevado na implementação e manutenção;
- preocupações com a privacidade dos dados biométricos;
- possibilidade de falsos positivos e falsos negativos;
- vulnerabilidade a ataques de *spoofing*.

A autenticação biométrica é uma tecnologia promissora para aumentar a segurança e a conveniência do acesso a sistemas e recursos. No entanto, é importante considerar os custos, as preocupações com a privacidade e os riscos de segurança antes de implementar a biometria.

3.4. CERTIFICADOS DIGITAIS E PKI

Certificados digitais são documentos eletrônicos que comprovam a identidade de um usuário, dispositivo ou organização. Os certificados digitais são emitidos por Autoridades Certificadoras (ACs) confiáveis e são usados para autenticar e criptografar comunicações online.

A Infraestrutura de Chaves Públicas (PKI) é um conjunto de tecnologias, políticas e procedimentos que permitem a criação, distribuição e gerenciamento de certificados digitais. A PKI é usada para garantir a autenticidade, a integridade e a confidencialidade das comunicações online.

Funcionamento: durante o processo de autenticação, o usuário ou dispositivo apresenta seu certificado digital, que é verificado pela AC emissora. Se o certificado for válido e confiável, a identidade do usuário ou dispositivo é verificada e o acesso é concedido (WHITE, 2022).

Vantagens:

- alta segurança devido ao uso de criptografia de chave pública;
- autenticação forte e confiável;
- suporte para assinatura digital e criptografia de dados.

Desvantagens:

- complexidade na implementação e gerenciamento da PKI;
- custo elevado na emissão e renovação de certificados;
- dependência de Autoridades Certificadoras confiáveis.

Certificados digitais e PKI são tecnologias essenciais para garantir a segurança e a confiança nas comunicações *online*. Eles são amplamente utilizados em aplicações como comércio eletrônico, banca online e acesso a sistemas corporativos.

4. PROTOCOLOS DE AUTENTICAÇÃO E AUTORIZAÇÃO

Os **protocolos de autenticação e autorização** são fundamentais para a segurança e a interoperabilidade de sistemas modernos. Eles **estabelecem métodos padronizados para validar identidades e conceder acesso a recursos**.

4.1. LDAP

O **LDAP (*Lightweight Directory Access Protocol*)** é um protocolo aberto e neutro para acessar e gerenciar serviços de diretórios distribuídos na internet. Ele é amplamente utilizado para autenticação e busca de informações de diretório, como usuários, grupos e dispositivos.

O LDAP organiza dados em uma estrutura hierárquica, permitindo buscas eficientes por informações de identidade (HOWES, 2022).

- **Vantagens:** amplamente utilizado e suportado; bom desempenho em consultas de diretório.
- **Desvantagens:** complexidade na configuração e manutenção; foco principal em leitura, com limitações em operações de escrita.

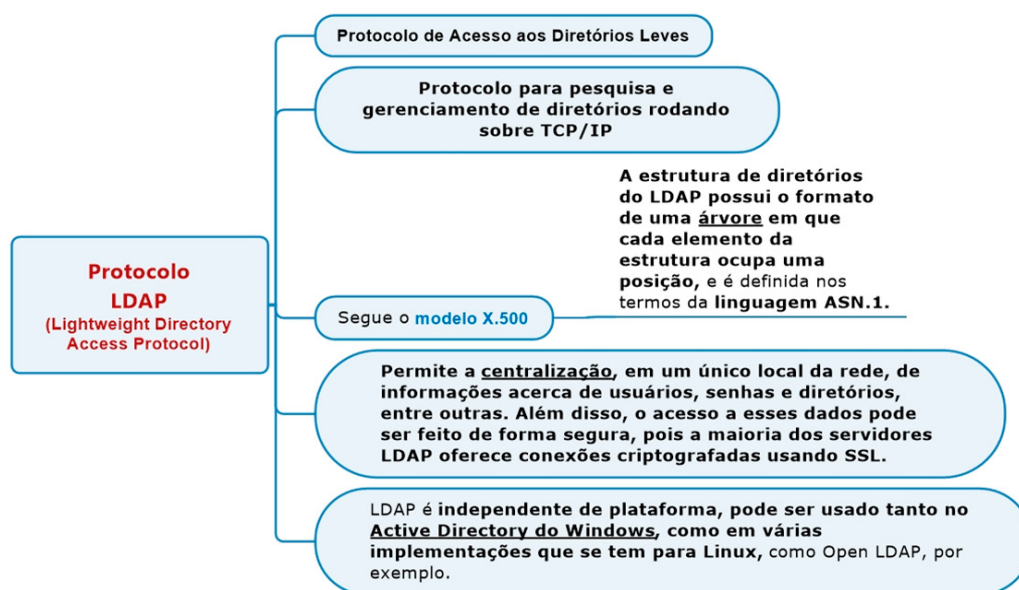


Figura. LDAP. Fonte: Quintão (2025)

4.2. SAML

O **SAML (Security Assertion Markup Language)** é um padrão aberto para intercâmbio de dados de autenticação e autorização entre domínios de segurança. É comumente usado para implementar Single Sign-On (SSO) em aplicações web.

O **SAML utiliza tokens XML para transmitir informações de autenticação entre o provedor de identidade e o provedor de serviços** (CANTOR, 2023).

- **Vantagens:** redução da necessidade de gerenciar múltiplas credenciais; facilitação do SSO em ambientes empresariais.
- **Desvantagens:** complexidade na implementação; formato XML pode ser mais pesado que alternativas como JWT.

4.3. OAUTH 2.0

O **OAuth 2.0** é um **protocolo de autorização que permite que aplicações obtenham acesso limitado ao usuário em um recurso HTTP, sem expor credenciais**. É amplamente utilizado por aplicações de terceiros para acessar serviços web, como APIs de redes sociais.

Utiliza **tokens** para conceder acesso limitado aos recursos, permitindo que os usuários autorizem o acesso sem compartilhar credenciais (HARDT, 2012).

- Vantagens: flexibilidade em acesso de aplicações de terceiros; boa segurança ao não expor credenciais diretas.

4.4. OPENID CONNECT

OpenID Connect é um **protocolo de autenticação que se baseia em OAuth 2.0 para adicionar um processo de autenticação**. Ele fornece uma verificação de identidade do usuário além da autorização de acesso.

Utiliza tokens JWT para transmitir as informações de autenticação e perfis de usuários entre o provedor de identidade e a aplicação (Sakimura et al., 2014).

- Vantagens: integração fácil com OAuth 2.0; suporte amplo e crescente. Desvantagens: depende do suporte ao OAuth 2.0.

5. SINGLE SIGN-ON (SSO)

5.1. CONCEITO E FUNCIONAMENTO

Single Sign-On (SSO) é uma tecnologia que **permite aos usuários acessar múltiplas aplicações ou sistemas usando uma única autenticação**. O SSO simplifica a experiência do usuário, eliminando a necessidade de lembrar várias senhas (GARCIA, 2023).

Quando um usuário faz *login* em um sistema que suporta SSO, um token de autenticação é gerado. Este token é usado para acessar outras aplicações conectadas sem pedir outra autenticação (SMITH, 2022).

5.2. VANTAGENS E DESVANTAGENS

Vantagens: simplifica a experiência do usuário; reduz o número de senhas que um usuário precisa gerenciar; aumenta a segurança ao reduzir chances de uso de senhas fracas (THOMAS, 2023).

Desvantagens: se uma conta de SSO for comprometida, múltiplos sistemas podem ser acessados de forma não autorizada; dependência de uma solução centralizada de autenticação (BROWN, 2024).

5.3. FEDERAÇÃO

Federação em autenticação é um conceito essencial para **permitir o Single Sign-On (SSO) sem a necessidade de senhas para cada sistema ou aplicação. Esse método utiliza padrões de identidade, como SAML (Security Assertion Markup Language) e WS-Federation**, para estabelecer um ambiente seguro e confiável em que as informações de identidade podem ser compartilhadas entre diferentes domínios.

Protocolo de identidade padrão: utiliza SAML ou WS-Federation para transmitir dados de identidade. Os protocolos geram tokens contendo informações de autenticidade do usuário.

Servidor de federação: atua como intermediário que emite tokens de identidade. Possui uma relação de confiança com os sistemas ou aplicações conectadas.

Uma vez autenticado por um servidor de federação, o usuário pode acessar diferentes sistemas sem precisar se autenticar novamente. **A confiança estabelecida entre os domínios** garante que o *token* apresentado seja aceito como prova válida de identidade.

A federação de identidades é uma solução robusta que combina segurança e conveniência. Ao facilitar o SSO com a eliminação da necessidade de múltiplas autenticações, ela melhora significativamente a experiência do usuário e aumenta a eficiência de gestão de acesso.

5.4. IMPLEMENTAÇÃO PRÁTICA

A implementação do SSO envolve a configuração de um provedor de identidade e a integração com aplicações de destino. Protocolos como SAML e OpenID Connect são comumente usados (JOHNSON, 2023).

DIRETO DO CONCURSO

005. (COMPERVE/UFRN/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO/2019) Atualmente, é muito comum a utilização de uma conta de usuário já criada em grandes provedores (como Facebook, Google e outros) para efetuar a autenticação em sistemas de terceiros. Para isso, as entidades envolvidas formam uma estrutura de confiança mútua. O conceito central utilizado é o de autenticação única ou SSO (do inglês, Single Sign-On). Com isso, o usuário não precisa realizar o cadastro em diferentes sites ou lembrar de múltiplas senhas. De acordo com a terminologia da área de segurança de redes, essa é uma autenticação do tipo

- mútua.
- federada.
- externa.
- facilitada.



- Certa. **Autenticação mútua** ocorre quando ambas as partes envolvidas em uma comunicação se autenticam mutuamente. Isso é comum em comunicações seguras, como em SSL/TLS, onde tanto o cliente quanto o servidor são verificados.
- Errada. **Autenticação federada** envolve a utilização de um provedor de identidade (como Facebook ou Google) para autenticar usuários em sistemas de terceiros. Uma relação de confiança é estabelecida entre o provedor de identidade e o serviço terceirizado, permitindo o Single Sign-On (SSO).
- Errada. **Autenticação externa** refere-se ao uso de um serviço externo para autenticar usuários. Isso pode incluir provedores de identidade que estão fora do domínio do sistema. No entanto, o termo “externa” é mais geral e não se refere especificamente à estrutura federada.
- Errada. Autenticação facilitada não é um termo padrão na área de segurança. Poderia implicar em métodos que tornam o processo mais simples para o usuário, mas não tem uma definição específica como os outros termos.

Nesse contexto, a autenticação federada é a descrição correta para o processo de SSO com provedores de identidade externos.

Letra b.

6. GESTÃO DE IDENTIDADES

6.1. CICLO DE VIDA DA IDENTIDADE

O ciclo de vida da identidade refere-se à criação, atualização, e remoção de identidades de usuários e suas correspondentes permissões (ROGERS, 2023).

6.2. PROVISIONAMENTO E DESPROVISIONAMENTO

Provisionamento é o processo de criar e gerenciar contas de usuários e suas permissões (WHITE, 2025).

Desprovisionamento envolve a remoção de acessos quando um usuário sai da organização ou muda de função.

6.3. SINCRONIZAÇÃO DE IDENTIDADES

A sincronização de identidades assegura que as informações dos usuários sejam consistentes e atualizadas em todos os sistemas. Isso é crítico para evitar inconsistências e problemas de acesso (LEE, 2024).

7. GOVERNANÇA DE ACESSO

7.1. POLÍTICAS DE ACESSO

Políticas de acesso definem quem pode acessar quais recursos e sob quais condições. Elas são essenciais para garantir a segurança e a conformidade (CARTER, 2023).

7.2. AUDITORIA E CONFORMIDADE

Auditorias regulares garantem que as políticas de acesso estão sendo seguidas e ajudam na detecção de anomalias. A conformidade com regulamentações é crucial para evitar sanções (LUCAS, 2022).

7.3. FERRAMENTAS DE GERENCIAMENTO DE ACESSO E IDENTIDADE

Ferramentas como plataformas IAM ajudam a automatizar os controles de acesso, simplificando a gestão e melhorando a segurança (DAVIS, 2024).

8. TENDÊNCIAS E INOVAÇÕES

8.1. IDENTIDADE COMO SERVIÇO (IDAAS)

A **Identidade como Serviço (IDaaS)** é uma solução baseada em nuvem que oferece funcionalidades de IAM sem a necessidade de infraestrutura local. Ela permite escalabilidade, flexibilidade e menor custo de implementação (BROWN, 2024).

8.2. BLOCKCHAIN PARA IDENTIDADE

Blockchain é um **livro-razão compartilhado e imutável** usado para **registrar transações**, **rastrear ativos** em uma rede empresarial e **aumentar a confiança** (IBM, 2020).

Obs.: Blockchain é um banco de dados público em que consta o histórico de todas as operações realizadas com a criptomoeda. São pedaços de código gerados *online* que carregam informações conectadas, como blocos de dados que formam uma corrente – por isso o nome “corrente de blocos”.

De acordo com IBM (2020), um *ativo* pode ser tangível (uma casa, um carro, dinheiro, terras) ou intangível (propriedade intelectual, patentes, direitos autorais e criação de marcas). Praticamente qualquer item de valor pode ser rastreado e negociado em uma rede de **blockchain**, o que reduz os riscos e os custos para todos os envolvidos.

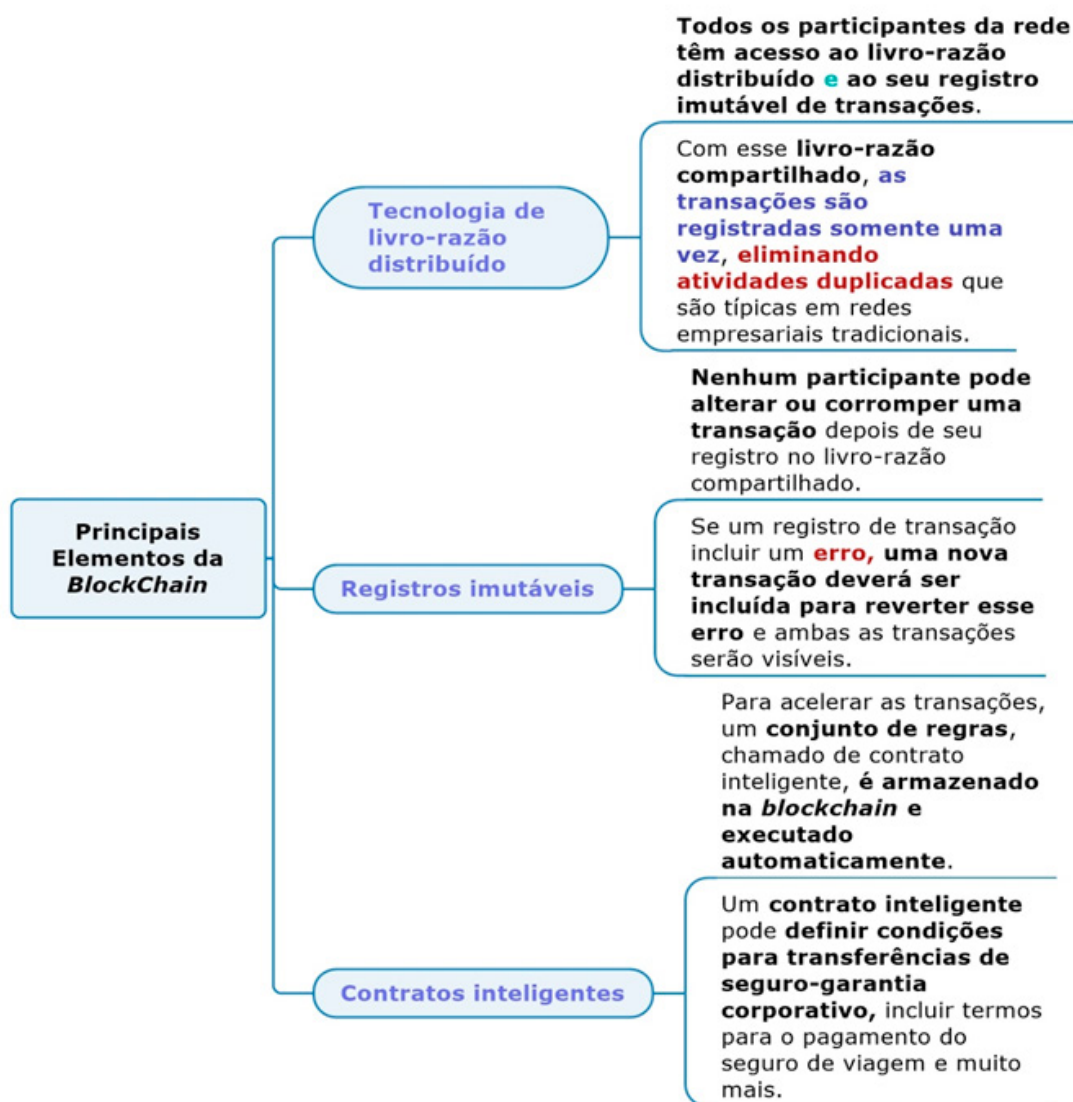


Figura. Principais Elementos da Blockchain (QUINTÃO, 2025)

- Uma característica de **blockchain** é o fato de que seus **registros de dados são mantidos em um banco de dados distribuído e são protegidos contra adulteração e revisão até mesmo dos operadores dos nós do armazenamento de dados** (Cespe/2021).

- Como a **blockchain** funciona (IBM,2020):
 - Cada transação é registrada como um “bloco” de dados, após sua ocorrência.
 - **Cada bloco está conectado aos anteriores e posteriores.**
 - As transações são bloqueadas em conjunto em uma cadeia irreversível: a **blockchain**.

Obs.: **Blockchain** é visto como uma tecnologia promissora para o gerenciamento de identidade. Ao usar um livro-razão distribuído, ele garante segurança, integridade e privacidade dos dados de identidade (DOE, 2023).

8.3. FUTURO DO GERENCIAMENTO DE IDENTIDADE

O futuro do gerenciamento de identidade está em integrar tecnologias emergentes como inteligência artificial e machine learning para prever e mitigar riscos de segurança. Espera-se também que o foco em privacidade e controle do usuário sobre suas próprias identidades continue a crescer (LEE, 2025).

RESUMO

1. Modelos de Controle de Acesso

- Controle de Acesso Discrecional (DAC)
- Controle de Acesso Obrigatório (MAC)
- Controle de Acesso Baseado em Função (RBAC)
- Controle de Acesso Baseado em Atributos (ABAC)

Veja a tabela comparativa que destaca os principais pontos de cada modelo:

CARACTERÍSTICA	DAC	MAC	RBAC	ABAC
Controle Decisão	Proprietário do recurso	Sistema	Funções	Atributos
Foco	Flexibilidade	Segurança	Gestão simplificada	Granularidade e Flexibilidade
Implementação	Simples	Complexa	Moderada	Complexa
Uso Ideal	Ambientes com baixa criticidade	Ambientes com alta criticidade	Organizações com funções bem definidas	Ambientes complexos com requisitos de acesso variados.
Exemplo	Permissões de arquivo em um SO	Acesso a documentos confidenciais em um sistema militar	Acesso a sistemas de RH baseado em cargos	Acesso a dados com base em localização, cargo e tipo de informação.
Vantagens	Flexibilidade, simplicidade	Segurança, Centralização	Facilidade de gestão, escalabilidade	Flexibilidade, precisão.
Desvantagens	Risco de má gestão, inconsistência	Complexidade, rigidez	Dependência da estrutura organizacional	Complexidade na definição das políticas.

Figura. Comparativo dos Modelos de Controle de Acesso. Fonte: (INÉDITA, 2025)



Obs.: IDENTIFICAÇÃO: é a capacidade de extrair informações de um usuário ou aplicação as quais o identifiquem unicamente.

AUTENTICAÇÃO: é a capacidade de garantir que um usuário, sistema ou informação é mesmo quem alega ser. A autenticação é essencial para a segurança dos sistemas, ao validar a identificação dos usuários, concedendo-lhes a **AUTORIZAÇÃO** para o acesso aos recursos.

A autenticação, em regra, depende de um ou mais modos ou fatores de autenticação, listados a seguir:

Algo que o usuário TEM/ POSSUI	São utilizados objetos específicos como cartões de identificação, smart cards, tokens USB.
Algo que o usuário CONHECE /SABE	São utilizadas senhas fixas, one-time passwords, sistemas de desafio-resposta.
Algo que o usuário É	Geralmente são usados meios biométricos, como impressão digital, padrão retinal, padrão de voz, reconhecimento de assinatura, reconhecimento facial.
ONDE o usuário ESTÁ	Quando o acesso a sistemas só pode ser realizado em uma máquina específica, cujo acesso é restrito.

Autenticação forte consiste na autenticação por mais de um modo, ou seja, da combinação de mais de uma maneira de autenticação. Um exemplo disso são as transações de saque num caixa rápido. Em regra, se utiliza:

- algo que você **TEM**: um cartão da conta bancária; e
- algo que você **SABE**: a senha do cartão.

QUESTÕES COMENTADAS EM AULA

001. (CESPE / CEBRASPE/BANESE - TÉCNICO BANCÁRIO III - ÁREA DE INFORMÁTICA – DESENVOLVIMENTO/2021) No que se refere a qualidade de software e segurança no desenvolvimento, julgue o item que se segue.

Um dos mecanismos de proteção para aplicações e servidores web é a autenticação, que permite o acesso apenas a usuários com as devidas credenciais.

002. (CESPE/SEFAZ-AL - AUDITOR DE FINANÇAS E CONTROLE DE ARRECADAÇÃO DA FAZENDA ESTADUAL/2020) Julgue o próximo item, relativo a segurança da informação.

Identificação e autenticação são requisitos de segurança da informação que consistem em identificar usuários do sistema e verificar as suas identidades, como pré-requisito para permitir o acesso desses usuários ao sistema.

003. (FADESP/TÉCNICO (PREF IGARAPÉ-MIRI)/INFORMÁTICA/2024) Ao comparar os mecanismos de autenticação de um fator e dois fatores, é correto afirmar que

a) a autenticação de dois fatores oferece maior segurança, mas é mais difícil de implementar do que a autenticação de um fator.

b) a autenticação de um fator oferece maior segurança porque requer apenas uma credencial para autenticação, enquanto que a autenticação de dois fatores é mais suscetível a ataques de phishing.

c) a autenticação de um fator oferece proteção adicional contra acessos não autorizados, mas pode ser contornada por usuários mal intencionados, tornando-se menos eficaz que a autenticação de dois fatores.

d) as autenticações de um fator e dois fatores possuem o mesmo nível de segurança, mas a autenticação de dois fatores é mais conveniente para o usuário.

004. (CESPE / CEBRASPE)/SERPRO/ANALISTA - ESPECIALIZAÇÃO: DESENVOLVIMENTO DE SISTEMAS/2021) No que se refere a autenticação e riscos de segurança, julgue o item subsequente. Os tokens de autenticação, que podem ser dispositivos físicos ou podem existir em software, geram códigos vinculados a determinado dispositivo, usuário ou conta, que podem ser usados uma vez como parte de um processo de autenticação em um intervalo de tempo.

005. (COMPERVE/UFRN/ANALISTA DE TECNOLOGIA DA INFORMAÇÃO/2019) Atualmente, é muito comum a utilização de uma conta de usuário já criada em grandes provedores (como Facebook, Google e outros) para efetuar a autenticação em sistemas de terceiros. Para isso, as entidades envolvidas formam uma estrutura de confiança mútua. O conceito central

utilizado é o de autenticação única ou SSO (do inglês, Single Sign-On). Com isso, o usuário não precisa realizar o cadastro em diferentes sites ou lembrar de múltiplas senhas. De acordo com a terminologia da área de segurança de redes, essa é uma autenticação do tipo

- a) mútua.
- b) federada.
- c) externa.
- d) facilitada.

QUESTÕES DE CONCURSO

006. (CESPE / CEBRASPE/SEFAZ-AL/AUDITOR FISCAL DE FINANÇAS E CONTROLE DE ARRECADAÇÃO DA FAZENDA ESTADUAL/2021) Quanto à segurança da informação, julgue o item subsecutivo. O uso de senhas ou a adoção de identificação física, como biometrias, são formas de autenticação para fins de identificação única e exclusiva de usuários.

007. (CESPE / CEBRASPE/SEFAZ-CE - AUDITOR FISCAL DE TECNOLOGIA DA INFORMAÇÃO DA RECEITA ESTADUAL/2021) A respeito de autenticação de dois fatores e OWASP Top 10, julgue o item a seguir. Códigos de verificação de um sistema de autenticação de dois fatores podem ser enviados por email ou gerados por um aplicativo autenticador instalado no dispositivo móvel do usuário.

008. (FGV/BANESTES/ANALISTA EM TECNOLOGIA DA INFORMAÇÃO - SEGURANÇA DA INFORMAÇÃO/2021) Para acessar a intranet corporativa, um colaborador informa seu CPF, senha pessoal e um código enviado para o seu celular cadastrado. O mecanismo de reforço implementado nessa intranet para confirmar a identidade do usuário contra acessos indevidos é a autenticação:

- a) biométrica;
- b) Kerberos;
- c) OAuth2;
- d) 2FA;
- e) Openid.

009. (VUNESP/CÂMARA DE PIRACICABA – SP/ADMINISTRADOR DE REDE/2019) Apesar dos benefícios do Logon Único (Single Sign-On), ele representa um relaxamento na segurança, pois a) requer que as credenciais de acesso do usuário sejam armazenadas utilizando criptografia reversível.

- b) aumenta o impacto negativo caso as credenciais de acesso venham a ser comprometidas.
- c) as credenciais de acesso ficam armazenadas em cache e podem ser acessadas mais facilmente por um atacante.
- d) permite que vários sistemas tenham acesso às credenciais de acesso do usuário.
- e) permite que um sistema que o usuário tenha acessado possua dados de outro sistema sem o consentimento do usuário.

010. (INÉDITA/2025) A autenticação de um fator é suficiente para proteger informações sensíveis em sistemas modernos.

- 011.** (INÉDITA/2025) A autenticação de dois fatores pode incluir algo que o usuário possui, como um token físico ou um código enviado por SMS.
- 012.** (INÉDITA/2025) A autenticação mútua exige que apenas o cliente confirme sua identidade para iniciar uma comunicação segura.
- 013.** (INÉDITA/2025) Na autenticação federada, usuários podem acessar múltiplos sistemas com um único conjunto de credenciais.
- 014.** (INÉDITA/2025) Autenticação externa significa que as credenciais de acesso do usuário são armazenadas diretamente em todos os sistemas acessados.
- 015.** (INÉDITA/2025) O Single Sign-On (SSO) reduz a necessidade de lembrar múltiplas senhas, mas aumenta o risco caso as credenciais sejam comprometidas.
- 016.** (INÉDITA/2025) O uso de criptografia reversível para armazenar senhas é uma prática recomendada para sistemas de autenticação.
- 017.** (INÉDITA/2025) Tokens de autenticação usados em SSO são um exemplo de como a autenticação federada pode ser implementada.
- 018.** (INÉDITA/2025) Autenticação de dois fatores sempre requer um dispositivo móvel para envio de códigos de verificação.
- 019.** (INÉDITA/2025) A autenticação biométrica é um método de autenticação baseado em características físicas únicas do usuário.
- 020.** (INÉDITA/2025) Em sistemas de autenticação mútua, tanto o servidor quanto o cliente se autenticam mutuamente.
- 021.** (INÉDITA/2025) O uso de autenticação de dois fatores elimina totalmente os riscos de segurança associados a credenciais comprometidas.
- 022.** (CESPE/SEFAZ-RS/TÉCNICO TRIBUTÁRIO DA RECEITA ESTADUAL - PROVA 1/2018) A respeito de segurança da informação, julgue os itens a seguir.
- I – Autenticidade se refere às ações tomadas para assegurar que informações confidenciais e críticas não sejam roubadas do sistema.
- II – A gestão de segurança da informação deve garantir a disponibilidade da informação.
- III – A confidencialidade garante a identidade de quem envia a informação.
- IV – De acordo com o conceito de integridade, os dados devem ser mantidos intactos, sem alteração, conforme foram criados e fornecidos.

Estão certos apenas os itens

- a) I e II.
- b) I e III.
- c) II e IV
- d) I, III e IV
- e) II, III e IV.

023. (CESPE/DPU/ANALISTA/2016) A respeito da Internet e suas ferramentas, julgue o item a seguir.

Integridade, confidencialidade e disponibilidade da informação, conceitos fundamentais de segurança da informação, são adotados na prática, nos ambientes tecnológicos, a partir de um conjunto de tecnologias como, por exemplo, criptografia, autenticação de usuários e equipamentos redundantes.

024. (FCC/TRE-CE/ANALISTA JUDICIÁRIO/ANÁLISE DE SISTEMAS/2012) Em relação à segurança da informação, considere:

I – Capacidade do sistema de permitir que alguns usuários acessem determinadas informações, enquanto impede que outros, não autorizados, sequer as consultem.

II – Informação exposta, sob risco de manuseio (alterações não aprovadas e fora do controle do proprietário da informação) por pessoa não autorizada.

III – O sistema deve ter condições de verificar a identidade dos usuários, e este ter condições de analisar a identidade do sistema.

Os itens I, II e III, associam-se, direta e respectivamente, aos princípios de

- a) confidencialidade, integridade e autenticidade.
- b) autenticidade, confidencialidade e irretratabilidade.
- c) confidencialidade, confidencialidade e irretratabilidade.
- d) autenticidade, confidencialidade e autenticidade.
- e) integridade, confidencialidade e integridade.

025. (CESPE/ABIN/OFICIAL TÉCNICO DE INTELIGÊNCIA - ÁREA 9/2018) Acerca de OAuth e LDAP (Lightweight Directory Access Protocol), julgue o item seguinte.

LDAP é um protocolo de diretórios que provê repositórios de informações de recursos de sistemas e serviços dentro de um ambiente centralizado e estritamente relacionado ao servidor. Por questão de limitação do padrão x.500, do qual foi originado, o LDAP não suporta funções de segurança e de acesso de cliente.

026. (CESPE/2008/CBM-DF/ ENGENHEIRO DE REDES DE COMUNICAÇÃO) Julgue os itens seguintes, acerca de sistemas operacionais, seus diversos tipos e características. O LDAP (lightweight directory access protocol) é um protocolo útil quando se trata de gerenciamento de autenticação em sistemas Linux, pois permite a centralização, em um único local da rede, de informações acerca de usuários, senhas e diretórios, entre outras. Além disso, o acesso a esses dados pode ser feito de forma segura, pois a maioria dos servidores LDAP oferece conexões criptografadas usando SSL (secure socket layer).

027. (FCC/TRT - 15ª REGIÃO (SP)/TÉCNICO JUDICIÁRIO - TECNOLOGIA DA INFORMAÇÃO/2015) Quanto ao LDAP:

- a) é baseado no padrão X.500, sendo o adequado substituto para banco de dados relacional, file system ou DNS.
- b) é o protocolo principal para acesso ao Active Directory e um protocolo padrão para acesso a diretórios administrados por meio do TCP/IP.
- c) aplicações LDAP podem ser agrupadas em até 2 categorias que são: apps para localizar usuários nos bancos de dados; e apps que gerenciam estes usuários.
- d) na estrutura de um diretório LDAP as informações são armazenadas no padrão objeto-relacional.
- e) apesar de ser mono-plataforma, não é comercializado como open source.

028. (FCC/TCE-AP/ANALISTA DE CONTROLE EXTERNO - CONTROLE EXTERNO TECNOLOGIA DA INFORMAÇÃO/2012)

Protocolo que organiza as informações como uma árvore e permite localizar pessoas, recursos e serviços, entre outros. Descrito na RFC 2251, é uma versão simplificada do serviço X.500 do OSI. Trata-se do

- a) LCP.
- b) IMAP.
- c) LDAP.
- d) DNS.
- e) ICMP.

029. (FCC/TRT 14ª/ANALISTA JUDICIÁRIO - TECNOLOGIA DA INFORMAÇÃO/2011)

O sistema LDAP é derivado de um sistema de diretórios chamado

- a) Frame Relay.
- b) ATM.
- c) DoS.
- d) X.500.
- e) DNS.

030. (FCC/MPE-RN/ANALISTA DE TI/2010) Podem ser consideradas características do LDAP: organização de servidores de forma hierárquica; substituição dos bancos de dados relacionais; multiplataforma; padrão aberto; grande escalabilidade.

GABARITO

1. C
2. C
3. a
4. C
5. b
6. C
7. C
8. d
9. d
10. E
11. C
12. E
13. C
14. E
15. C
16. E
17. C
18. E
19. C
20. C
21. E
22. c
23. C
24. a
25. e
26. C
27. b
28. c
29. d
30. E

GABARITO COMENTADO

006. (CESPE / CEBRASPE/SEFAZ-AL/AUDITOR FISCAL DE FINANÇAS E CONTROLE DE ARRECAÇÃO DA FAZENDA ESTADUAL/2021) Quanto à segurança da informação, julgue o item subsecutivo. O uso de senhas ou a adoção de identificação física, como biometrias, são formas de autenticação para fins de identificação única e exclusiva de usuários.



A **autenticação**, em regra, **depende** de um ou mais **modos ou fatores de autenticação**, os quais ajudam a verificar a identidade dos usuários. Os fatores de identificação mais comumente usados são listados a seguir:

Algo que o usuário CONHECE /SABE	São utilizadas senhas fixas , <i>one-time passwords</i> , sistemas de desafio-resposta.
Algo que o usuário TEM/ Possui	São utilizados objetos específicos como cartões de identificação, <i>tokens</i> USB, smartphone que receberá e-mail ou SMS com código a ser apresentado.
Algo que o usuário É	Geralmente são usados meios biométricos , como impressão digital, padrão retinal, padrão de voz, reconhecimento de assinatura, reconhecimento facial.
ONDE o usuário ESTÁ	Quando o acesso a sistemas só pode ser realizado em uma máquina específica, cujo acesso é restrito.

Certo.

007. (CESPE / CEBRASPE/SEFAZ-CE - AUDITOR FISCAL DE TECNOLOGIA DA INFORMAÇÃO DA RECEITA ESTADUAL/2021) A respeito de autenticação de dois fatores e OWASP Top 10, julgue o item a seguir. Códigos de verificação de um sistema de autenticação de dois fatores podem ser enviados por email ou gerados por um aplicativo autenticador instalado no dispositivo móvel do usuário.



No sistema de autenticação de dois fatores (2FA - 2-Factor Authentication), os códigos de verificação podem ser enviados ao usuário por email ou podem ser gerados por um aplicativo autenticador instalado no dispositivo móvel do usuário. Essas práticas adicionam uma camada extra de segurança, garantindo que mesmo que uma senha seja comprometida, o acesso ainda requer uma segunda verificação.

Certo.

008. (FGV/BANESTES/ANALISTA EM TECNOLOGIA DA INFORMAÇÃO - SEGURANÇA DA INFORMAÇÃO/2021) Para acessar a intranet corporativa, um colaborador informa seu CPF, senha pessoal e um código enviado para o seu celular cadastrado. O mecanismo de reforço implementado nessa intranet para confirmar a identidade do usuário contra acessos indevidos é a autenticação:

- a) biométrica;
- b) Kerberos;
- c) Oauth2;
- d) 2FA;
- e) Openid.



O mecanismo descrito é a autenticação de dois fatores (2FA), pois envolve algo que o colaborador sabe (CPF e senha) e algo que ele possui (código enviado para o celular).

Letra d.

009. (VUNESP/CÂMARA DE PIRACICABA – SP/ADMINISTRADOR DE REDE/2019) Apesar dos benefícios do Logon Único (Single Sign-On), ele representa um relaxamento na segurança, pois

- a) requer que as credenciais de acesso do usuário sejam armazenadas utilizando criptografia reversível.

- b) aumenta o impacto negativo caso as credenciais de acesso venham a ser comprometidas.
- c) as credenciais de acesso ficam armazenadas em cache e podem ser acessadas mais facilmente por um atacante.
- d) permite que vários sistemas tenham acesso às credenciais de acesso do usuário.
- e) permite que um sistema que o usuário tenha acessado possua dados de outro sistema sem o consentimento do usuário.



a) Errada. Armazenar credenciais usando criptografia reversível não é uma prática recomendada, pois ela implica que as credenciais possam ser descriptografadas. O SSO não requer necessariamente esse tipo de armazenamento; em muitos casos, são usadas práticas mais seguras, como hash unidirecional.

b) Certa. Com SSO, se as credenciais forem comprometidas, um invasor pode acessar todos os sistemas vinculados, agravando as consequências.

c) Errada. Armazenar credenciais em cache pode ser uma prática insegura, mas não é inerente ao SSO. As boas práticas de segurança podem mitigar esse risco.

d) Errada. No SSO, os sistemas não recebem as credenciais do usuário; em vez disso, um token de autenticação é utilizado. O acesso direto às credenciais não acontece.

e) Errada. SSO não implica automaticamente no compartilhamento de dados entre sistemas sem consentimento do usuário. A autorização de acesso a dados é gerenciada separadamente das autenticações SSO.

Letra d.

010. (INÉDITA/2025) A autenticação de um fator é suficiente para proteger informações sensíveis em sistemas modernos.



A autenticação de um fator é geralmente considerada insuficiente para proteger informações sensíveis, pois depende de um único ponto de falha.

Errado.

011. (INÉDITA/2025) A autenticação de dois fatores pode incluir algo que o usuário possui, como um token físico ou um código enviado por SMS.



A **Autenticação de Dois Fatores (2FA)** é uma **camada adicional de segurança** que **exige que os usuários forneçam dois fatores de autenticação diferentes para verificar sua identidade.**

Funcionamento: após fornecer sua senha (primeiro fator), o usuário é solicitado a fornecer um segundo fator de autenticação, como um código enviado para seu *smartphone* via SMS, um código gerado por um aplicativo autenticador ou uma impressão digital (BROWN, 2024).

Certo.

012. (INÉDITA/2025) A autenticação mútua exige que apenas o cliente confirme sua identidade para iniciar uma comunicação segura.



A autenticação mútua requer que ambas as partes (cliente e servidor) confirmem suas identidades.

Errado.

013. (INÉDITA/2025) Na autenticação federada, usuários podem acessar múltiplos sistemas com um único conjunto de credenciais.



Na autenticação federada, uma única credencial pode ser usada para acessar múltiplos sistemas confiáveis.

Usando um protocolo de identidade padrão, como Linguagem de Aumento da Segurança da Declaração (SAML - Security Assertion Markup Language) ou WS-Federation, um servidor de federação apresenta um token (dados de identidade) para um sistema ou uma aplicação com a qual tem uma relação de confiança estabelecida. Por causa dessa confiança, os usuários podem se mover livremente entre os domínios conectados, sem precisar se autenticar novamente.

Certo.

014. (INÉDITA/2025) Autenticação externa significa que as credenciais de acesso do usuário são armazenadas diretamente em todos os sistemas acessados.



Na autenticação externa, as credenciais são geridas por um provedor de identidade, não armazenadas em cada sistema acessado.

Errado.

015. (INÉDITA/2025) O Single Sign-On (SSO) reduz a necessidade de lembrar múltiplas senhas, mas aumenta o risco caso as credenciais sejam comprometidas.



SSO simplifica o gerenciamento de senhas, mas um único conjunto de credenciais comprometido pode afetar vários sistemas.

Certo.

016. (INÉDITA/2025) O uso de criptografia reversível para armazenar senhas é uma prática recomendada para sistemas de autenticação.



O uso de criptografia reversível para armazenar senhas não é recomendado devido ao risco de comprometimento.

Errado.

017. (INÉDITA/2025) Tokens de autenticação usados em SSO são um exemplo de como a autenticação federada pode ser implementada.



Tokens de autenticação são usados em SSO e são um exemplo de como a autenticação federada funciona.

Certo.

018. (INÉDITA/2025) Autenticação de dois fatores sempre requer um dispositivo móvel para envio de códigos de verificação.



Embora comum, a 2FA não requer sempre um dispositivo móvel; pode usar métodos diferentes como biometria ou chaves físicas.

Errado.

019. (INÉDITA/2025) A autenticação biométrica é um método de autenticação baseado em características físicas únicas do usuário.



A autenticação biométrica se baseia em características físicas únicas, como impressão digital ou reconhecimento facial.

Certo.

020. (INÉDITA/2025) Em sistemas de autenticação mútua, tanto o servidor quanto o cliente se autenticam mutuamente.



Em autenticação mútua, tanto o cliente quanto o servidor se autenticam, garantindo confiança mútua.

Certo.

021. (INÉDITA/2025) O uso de autenticação de dois fatores elimina totalmente os riscos de segurança associados a credenciais comprometidas.



A autenticação de dois fatores reduz significativamente os riscos, mas não os elimina totalmente. É uma camada adicional de segurança.

Errado.

022. (CESPE/SEFAZ-RS/TÉCNICO TRIBUTÁRIO DA RECEITA ESTADUAL - PROVA 1/2018) A respeito de segurança da informação, julgue os itens a seguir.

I – Autenticidade se refere às ações tomadas para assegurar que informações confidenciais e críticas não sejam roubadas do sistema.

II – A gestão de segurança da informação deve garantir a disponibilidade da informação.

III – A confidencialidade garante a identidade de quem envia a informação.

IV – De acordo com o conceito de integridade, os dados devem ser mantidos intactos, sem alteração, conforme foram criados e fornecidos.

Estão certos apenas os itens

- a) I e II.
- b) I e III.
- c) II e IV
- d) I, III e IV
- e) II, III e IV.



A **C**onfidencialidade, a **I**ntegridade, a **D**isponibilidade são três conceitos fundamentais de segurança da informação.

Eles formam aquilo que chamamos de pirâmide ou **tríade** da Segurança da Informação (É possível encontrar a sigla **CID**, para fazer menção às iniciais desses 3 princípios!).

Princípio	Característica	Dica Complementar
C onfidencialidade (ou sigilo)	É a garantia de que a informação não será conhecida por quem não deve. O acesso às informações deve ser limitado, ou seja, somente as pessoas explicitamente autorizadas podem acessá-las.	Manter a confidencialidade pressupõe assegurar que as pessoas não tomem conhecimento de informações, de forma acidental ou proposital, sem que possuam autorização para tal procedimento. Refere-se, portanto, às ações tomadas para assegurar que informações confidenciais e críticas não sejam roubadas do sistema (Item I, errado.)
I ntegridade	É a garantia de que a informação que foi armazenada é a que será recuperada. A integridade busca proteção contra codificação não autorizada. Modificação deve ser realizada somente pelas partes devidamente autorizadas.	A manutenção da integridade pressupõe a garantia de não violação dos dados com intuito de alteração, gravação ou exclusão, seja ela acidental ou proposital. De acordo com o conceito de integridade, os dados devem ser mantidos intactos, sem alteração, conforme foram criados e fornecidos (Item IV correto).
D isponibilidade	Busca acesso disponível às entidades autorizadas sempre que necessário.	Manter a disponibilidade pressupõe garantir a prestação contínua do serviço, sem interrupções no fornecimento de informações para quem é de direito.
A utenticidade	O receptor (destinatário de uma mensagem) pode confirmar que a assinatura foi feita pelo emissor.	A autenticidade garante a identidade de quem envia a informação (Item III errado).

Com o A, de Autenticidade, teremos o CIDA! Por fim, destacamos que a gestão de segurança da informação deve garantir a disponibilidade/confidencialidade/ integridade da informação, assim o item II está correto.

Letra c.

023. (CESPE/DPU/ANALISTA/2016) A respeito da Internet e suas ferramentas, julgue o item a seguir. Integridade, confidencialidade e disponibilidade da informação, conceitos fundamentais de segurança da informação, são adotados na prática, nos ambientes tecnológicos, a partir de um conjunto de tecnologias como, por exemplo, criptografia, autenticação de usuários e equipamentos redundantes.



A **Confidencialidade**, a **Integridade** e a **Disponibilidade** são três conceitos fundamentais de segurança da informação.

Eles formam aquilo que chamamos de **pirâmide** ou **tríade** da Segurança da Informação (É possível encontrar a sigla **CID**, para fazer menção às iniciais desses 3 princípios!).

Princípio	Característica	Dica Complementar
Confidencialidade (ou sigilo)	É a garantia de que a informação não será conhecida por quem não deve. O acesso às informações deve ser limitado, ou seja, somente as pessoas explicitamente autorizadas podem acessá-las.	Manter a confidencialidade pressupõe assegurar que as pessoas não tomem conhecimento de informações, de forma acidental ou proposital, sem que possuam autorização para tal procedimento.
Integridade	É a garantia de que a informação que foi armazenada é a que será recuperada. A integridade busca proteção contra codificação não autorizada. Modificação deve ser realizada somente pelas partes devidamente autorizadas.	A manutenção da integridade pressupõe a garantia de não violação dos dados com intuito de alteração, gravação ou exclusão, seja ela acidental ou proposital.
Disponibilidade	Busca acesso disponível às entidades autorizadas sempre que necessário.	Manter a disponibilidade pressupõe garantir a prestação contínua do serviço, sem interrupções no fornecimento de informações para quem é de direito.

Esses **princípios** são aplicados na prática, nos ambientes tecnológicos, a partir de um **conjunto de controles** como, por exemplo, **criptografia**, **autenticação de usuários e equipamentos redundantes** (um sistema redundante possui um segundo dispositivo que está imediatamente disponível para uso quando da falha do dispositivo principal).

Aspecto	Descrição	Medidas de Controle
Confidencialidade	Garantia que a informação não será conhecida por quem não deve	Classificação da informação, criptografia.
Integridade	Garantia que a informação que foi armazenada é a que será recuperada	Autenticação de usuários e implementação de controle de acesso.
Disponibilidade	Garantia que a informação sempre poderá ser acessada	Plano de contingência Uso de equipamentos redundantes, etc.

Certo.

024. (FCC/TRE-CE/ANALISTA JUDICIÁRIO/ANÁLISE DE SISTEMAS/2012) Em relação à segurança da informação, considere:

I – Capacidade do sistema de permitir que alguns usuários acessem determinadas informações, enquanto impede que outros, não autorizados, sequer as consultem.

II – Informação exposta, sob risco de manuseio (alterações não aprovadas e fora do controle do proprietário da informação) por pessoa não autorizada.

III – O sistema deve ter condições de verificar a identidade dos usuários, e este ter condições de analisar a identidade do sistema.

Os itens I, II e III, associam-se, direta e respectivamente, aos princípios de

- a) confidencialidade, integridade e autenticidade.
- b) autenticidade, confidencialidade e irretratabilidade.
- c) confidencialidade, confidencialidade e irretratabilidade.
- d) autenticidade, confidencialidade e autenticidade.
- e) integridade, confidencialidade e integridade.



Vamos à caracterização dos princípios destacados na questão:

Item I. **Confidencialidade** (sigilo): é a garantia de que a informação não será conhecida por quem não deve. O acesso às informações deve ser limitado, ou seja, somente as pessoas explicitamente autorizadas podem acessá-las.

Item II. **Integridade**: esse princípio destaca que a informação deve ser mantida na condição em que foi liberada pelo seu proprietário, garantindo a sua proteção CONTRA MUDANÇAS INTENCIONAIS, INDEVIDAS OU ACIDENTAIS. Em outras palavras, é a garantia de que a informação que foi armazenada é a que será recuperada!!! O fato de se ter a informação exposta, com alterações não aprovadas e fora do controle do proprietário da informação por pessoa não autorizada está relacionada a esse princípio.

Item III. **Autenticidade**: é a capacidade de garantir a IDENTIDADE de uma pessoa (física ou jurídica) que acessa as informações do sistema ou de um servidor (computador) com quem se estabelece uma transação (de comunicação, como um *e-mail*, ou comercial, como uma venda *on-line*). **É por meio da autenticação que se confirma a identidade da pessoa ou entidade que presta ou acessa as informações.**

Letra a.

025. (CESPE/ABIN/OFICIAL TÉCNICO DE INTELIGÊNCIA - ÁREA 9/2018) Acerca de OAuth e LDAP (Lightweight Directory Access Protocol), julgue o item seguinte.

LDAP é um protocolo de diretórios que provê repositórios de informações de recursos de sistemas e serviços dentro de um ambiente centralizado e estritamente relacionado ao servidor. Por questão de limitação do padrão x.500, do qual foi originado, o LDAP não suporta funções de segurança e de acesso de cliente.



LDAP (*Lightweight Directory Access Protocol*) é o protocolo principal para acesso ao Active Directory e um protocolo padrão para pesquisa e gerenciamento de diretórios rodando sobre TCP/IP. Um diretório LDAP segue o modelo X.500, que é uma estrutura hierárquica de nós chamada de *Directory Information Tree* (DIT), cada um consistindo de um conjunto de atributos com seus respectivos valores. **LDAP suporta funções de segurança e de acesso de cliente**. Como exemplo, tem a operação StartTLS – a partir da versão 3 do LDAP, que protege a conexão com criptografia (por meio do protocolo TLS).

Errado.

026. (CESPE/2008/CBM-DF/ ENGENHEIRO DE REDES DE COMUNICAÇÃO) Julgue os itens seguintes, acerca de sistemas operacionais, seus diversos tipos e características. O LDAP (lightweight directory access protocol) é um protocolo útil quando se trata de gerenciamento de autenticação em sistemas Linux, pois permite a centralização, em um único local da rede, de informações acerca de usuários, senhas e diretórios, entre outras. Além disso, o acesso a esses dados pode ser feito de forma segura, pois a maioria dos servidores LDAP oferece conexões criptografadas usando SSL (secure socket layer).



O LDAP (*lightweight directory access protocol*) é independente de plataforma, pode ser usado tanto no AD do Windows, como em várias implementações que se tem para Linux, como Open LDAP, por exemplo. Além disso, LDAP pode oferecer conexões criptografadas para trafegar as informações de forma segura.

Certo.

027. (FCC/TRT - 15ª REGIÃO (SP)/TÉCNICO JUDICIÁRIO - TECNOLOGIA DA INFORMAÇÃO/2015) Quanto ao LDAP:

- a) é baseado no padrão X.500, sendo o adequado substituto para banco de dados relacional, file system ou DNS.
- b) é o protocolo principal para acesso ao Active Directory e um protocolo padrão para acesso a diretórios administrados por meio do TCP/IP.
- c) aplicações LDAP podem ser agrupadas em até 2 categorias que são: apps para localizar usuários nos bancos de dados; e apps que gerenciam estes usuários.
- d) na estrutura de um diretório LDAP as informações são armazenadas no padrão objeto-relacional.
- e) apesar de ser mono-plataforma, não é comercializado como open source.



a) Errada. LDAP (*Lightweight Directory Access Protocol*) é baseado no padrão X.500, mas não é o substituto para banco de dados relacional, file system ou DNS.

Limitações:

- Não substitui Banco de Dados Relacionais (heavy updates, processamento transacional, geração de relatórios, SQL, two phase commit).
- Não é um *file system*, dificultando o armazenamento de BLOB (binary large objects).
- Não serve como base para uma solução DNS, não funciona “connectionless” como o DNS.

b) Certa. **LDAP (*Lightweight Directory Access Protocol*)** é o protocolo principal para acesso ao Active Directory e um protocolo padrão para pesquisa e gerenciamento de diretórios rodando sobre TCP/IP, criado como uma alternativa ao protocolo *Directory Access Protocol* (DAP), que era mais difícil de utilizar, e era derivado da família de padrões X.500 da ITU-T.

c) Errada. Aplicações LDAP podem ser agrupadas em até 3 categorias que são: apps para localizar usuários e recursos na rede, apps que gerenciam estes usuários e recursos, apps de autenticação e segurança.

d) Errada. Um diretório LDAP segue o modelo X.500, que é uma estrutura hierárquica de nós chamada de *Directory Information Tree* (DIT), cada um consistindo de um conjunto de atributos com seus respectivos valores.



e) Errada. São multiplataformas (Multi-plataforma – aplicações LDAP-aware). Opções de fornecedores de solução: comercial, open source.

Veja mais: https://memoria.rnp.br/_arquivo/sci/2000/ldap.pdf

Letra b.

028. (FCC/TCE-AP/ANALISTA DE CONTROLE EXTERNO - CONTROLE EXTERNO TECNOLOGIA DA INFORMAÇÃO/2012)

Protocolo que organiza as informações como uma árvore e permite localizar pessoas, recursos e serviços, entre outros. Descrito na RFC 2251, é uma versão simplificada do serviço X.500 do OSI. Trata-se do

- a) LCP.
- b) IMAP.
- c) LDAP.
- d) DNS.
- e) ICMP.



O LDAP (*Lightweight Directory Access Protocol*) está diretamente relacionado com o X.500. Ele foi originalmente desenhado como um protocolo simples para *desktops* com a função de gateway para os servidores de X.500.

Letra c.

029. (FCC/TRT 14ª/ANALISTA JUDICIÁRIO - TECNOLOGIA DA INFORMAÇÃO/2011) O sistema LDAP é derivado de um sistema de diretórios chamado

- a) Frame Relay.
- b) ATM.
- c) DoS.
- d) X.500.
- e) DNS.



O sistema **LDAP** é derivado de um sistema de diretórios chamado X.500.

Nota: X.500: “pesado” principalmente por requerer que o cliente e servidor utilizassem o protocolo OSI para comunicação. Por sua vez, o LDAP usa mensagens com baixa sobrecarga que são mapeadas diretamente para a camada de TCP (porta padrão 389 e 636 sobre SSL) do TCP/IP.

Letra d.

030. (FCC/MPE-RN/ANALISTA DE TI/2010) Podem ser consideradas características do LDAP: organização de servidores de forma hierárquica; substituição dos bancos de dados relacionais; multiplataforma; padrão aberto; grande escalabilidade.



A banca costuma tratar o **LDAP** (*Lightweight Directory Access Protocol*) como um serviço de diretórios, mas, na verdade ele é um **protocolo** de acesso ao serviço de diretórios.

A **função** do LDAP é organizar os recursos de rede de forma hierárquica, como uma árvore de diretório. LDAP é uma versão simplificada do padrão para sistema de diretórios chamado **X.500**.

São características relacionadas ao **LDAP**:

- organização de servidores de forma hierárquica;
- multiplataforma (pode ser usado tanto no Active Directory do Windows, como em várias implementações que se tem para Linux, como Open LDAP, por exemplo);
- baseado em padrão aberto;
- grande escalabilidade (é possível replicar servidores LDAP (com backup ou balanceamento de carga) e incluir novos servidores, à medida que cresce a estrutura da organização);
- oferta maior velocidade de consulta que um banco de dados relacional;
- disponibiliza esquemas padronizados para dados e consolidação de informações, é replicável e distribuível. A substituição dos bancos de dados relacionais não está relacionada ao LDAP. Normalmente um cliente conecta-se ao servidor LDAP, por meio da porta padrão 389 (TCP).

Errado.

REFERÊNCIAS

- Allen, R. **Data Protection Techniques. Privacy Today**. 2023. Disponível em: <www.privacytoday.com>. Acesso em: 18 mar. 2025.
- BIDGOLI, H. **Handbook of Information Security, Threats, Vulnerabilities, Prevention, Detection, and Management**. John Wiley & Sons, 2006.
- BROWN, A. **Exploring IDaaS. Cloud Security Journal**. 2024. Disponível em: <www.cloudsecurityjournal.com>. Acesso em: 18 mar. 2025.
- _____. **Understanding Multi-Factor Authentication**. 2024. Security Today. Disponível em: <www.cybersecuritymag.com>. Acesso em: 18 mar. 2025.
- Doe, J. **Blockchain and Identity. Distributed Ledger Review**. 2023. Disponível em: www.dlr.com. Acesso em: 18 mar. 2025.
- CANTOR, S. **Security Assertion Markup Language (SAML) Overview**. 2023. OASIS. Disponível em: <www.oasis-open.org>. Acesso em: 18 mar. 2025.
- CISCO. **O que é gerenciamento de identidade e acesso (IAM)?** Disponível em: <https://www.cisco.com/site/br/pt/products/security/index.html>. Acesso em: 18 mar. 2022.
- COMODO. **Digital Certificates and PKI**. 2022. Disponível em: <www.comodo.com>. Acesso em: 18 mar. 2025.
- GARCIA, L. **Biometric Authentication Methods**. 2023. Biometric Update. Disponível em: <www.biometricresearch.com>. Acesso em: 18 mar. 2025.
- HARDT, D. **The OAuth 2.0 Authorization Framework**. 2012.IETF. Disponível em: <www.rfc-editor.org>. Acesso em: 18 mar. 2025.
- HOWES, T. **Understanding LDAP - Design and Implementation**. 2022. Addison-Wesley. Disponível em: <ldap.com>. Acesso em: 18 mar. 2025.
- IBM. Artificial intelligence in medicine. Watson Health Learning Hub, Armonk, [25 Aug. 2020]. Disponível em: https://www.ibm.com/watson-health/learn/artificial-intelligence-medicine. Acesso em: 7 dez. 2020.
- _____. Disponível em: <https://www.ibm.com/br-pt/topics/what-is-blockchain>. Acesso em: dez. 2021.
- LEE, K. **The Future of Identity Management**. 2025. Identity Insights. Disponível em: <www.identityinsights.com>. Acesso em: 18 mar. 2025.

MICROCITY. **O que é o gerenciamento de identidade e acessos e qual a sua importância na segurança digital?** Disponível em: <https://www.microcity.com.br/gerenciamento-de-identidade-e-acessos/>. Acesso em: 18 mar. 2025.

OKTA. **What is Identity Management?** Disponível em: < <https://www.okta.com/iam-identity-and-access-management/> >. Acesso em: 18 mar. 2025.

QUINTÃO, P. L. **Notas de aula da disciplina “Tecnologia da Informação”**. 2025.

KHAN, T. **Common Vulnerabilities in Authentication Systems**. Cyber 2024. Defense Magazine. Disponível em: <www.cyberdefensemagazine.com>. Acesso em: 18 mar. 2025.

RAMOS, A.; BASTOS, A.; LAYRA, A. **Guia Oficial para Formação de Gestores em Segurança da Informação**. 1. ed. Rio Grande do Sul: ZOUK. 2006.

ROUSE, M. **Identity and Access Management (IAM)**. 2021. TechTarget. Disponível em: <<https://www.techtarget.com/searchsecurity/definition/identity-access-management-IAM-system>>. Acesso em: 18 mar. 2025.

SAILPOINT. **What is Identity and Access Management (IAM)?** Disponível em: < <https://www.sailpoint.com/identity-library/identity-and-access-management> >. Acesso em: 18 mar. 2025.

SAKIMURA, N., BRADLEY, J., JONES, M., DE MEDEIROS, B., & MORTIMORE, C. **OpenID Connect Core 1.0. OpenID Foundation**. 2014. Disponível em: <openid.net>. Acesso em: 18 mar. 2025.

SMITH, J. **Understanding GDPR and Global Regulations**. 2025. Global Data Compliance. Disponível em: <www.globaldatacompliance.com>. Acesso em: 18 mar. 2025.

_____. **The History of Passwords**. IEEE Security & Privacy. 2022. Disponível em: [URL inválido removido] Acesso em: 18 mar. 2025.

STAIR, R. M.; REYNOLDS, G. W. **Princípios de sistemas de informação: uma abordagem gerencial**. 4. ed. Rio de Janeiro: Livros Técnicos e Científicos, 2002.

STALLINGS, W., **Criptografia e Segurança de Redes: Princípios e Práticas**, 4. ed. São Paulo: Pearson Prentice-Hall, 2008.

SCHNEIER, B., **Applied Cryptography: Protocols, Algorithms and Source Code in C**. 2. ed. John Wiley & Sons, 1996.

NIST. **Password Security Best Practices**. 2023. Disponível em: <securityandprivacy.ieee.org>. Acesso em: 18 mar. 2025.

Abra



caminhos



crie

futuros

gran.com.br

